

# **Relazione di Laboratorio: Configurazione e Gestione delle Regole per i File di Log della Sicurezza in Windows**

---

# 1. Introduzione

## 1.1 Contesto e Obiettivi

Nel panorama contemporaneo della cybersecurity, la capacità di monitorare, registrare e analizzare le attività di sicurezza rappresenta un requisito imprescindibile per la difesa delle infrastrutture digitali. I file di log, e in particolare il registro di sicurezza di Windows, costituiscono la fonte primaria di evidenza digitale (*digital evidence*) per la rilevazione di accessi non autorizzati, l'analisi forense post-incidente e il soddisfacimento degli obblighi di conformità normativa.

L'esercitazione oggetto della presente relazione si colloca nell'ambito di un percorso formativo dedicato all'ethical hacking e alla sicurezza dei sistemi operativi. L'obiettivo primario consiste nel configurare il sistema operativo Microsoft Windows affinché registri in modo granulare gli eventi relativi agli accessi (*logon*) e alle disconnessioni (*logoff*) degli utenti, abilitando così un livello di visibilità essenziale per il monitoraggio della sicurezza. Gli obiettivi specifici dell'esercizio possono essere sintetizzati nei seguenti punti:

- Accedere al Visualizzatore eventi di Windows e navigare nel registro di sicurezza;
- Analizzare e configurare le proprietà del file di log della sicurezza, inclusi il percorso fisico, la dimensione massima e il comportamento in caso di raggiungimento della capacità massima;
- Abilitare, tramite l'Editor criteri di gruppo locali, le politiche di controllo avanzate (*Advanced Audit Policies*) per la tracciatura degli accessi riusciti e falliti, nonché delle disconnessioni;
- Verificare la corretta generazione degli eventi di sicurezza a seguito della configurazione applicata.

## 1.2 Ambito e Limitazioni

È necessario precisare esplicitamente che l'intera attività descritta nella presente relazione è stata condotta in un ambiente di laboratorio completamente isolato e controllato, costituito da una macchina virtuale dedicata allo svolgimento degli esercizi didattici. Nessuna delle operazioni documentate è stata eseguita su sistemi di produzione o su infrastrutture di proprietà di terzi. L'esercitazione è finalizzata esclusivamente all'acquisizione di competenze tecniche in ambito accademico e non comporta alcun intento di accesso non autorizzato, alterazione di sistemi informatici o violazione di normative in materia di sicurezza informatica.

## 1.3 Struttura della Relazione

Il documento è articolato in sezioni logiche che riflettono le diverse fasi operative dell'esercitazione. Dopo la descrizione dello scenario e dell'ambiente di lavoro, si procede con l'analisi dettagliata delle configurazioni effettuate, corredata dai riferimenti alle prove acquisite durante l'esercizio. Segue un'apposita sezione dedicata all'analisi dei rischi connessi alla gestione dei log di sicurezza e alle relative contromisure. La relazione si conclude con una riflessione sulle lezioni apprese e sulle implicazioni pratiche delle attività svolte.

---

## 2. Scenario e Ambiente di Laboratorio

L'esercitazione è stata condotta su una macchina virtuale ospitata in ambiente Oracle VirtualBox, configurata con le seguenti caratteristiche:

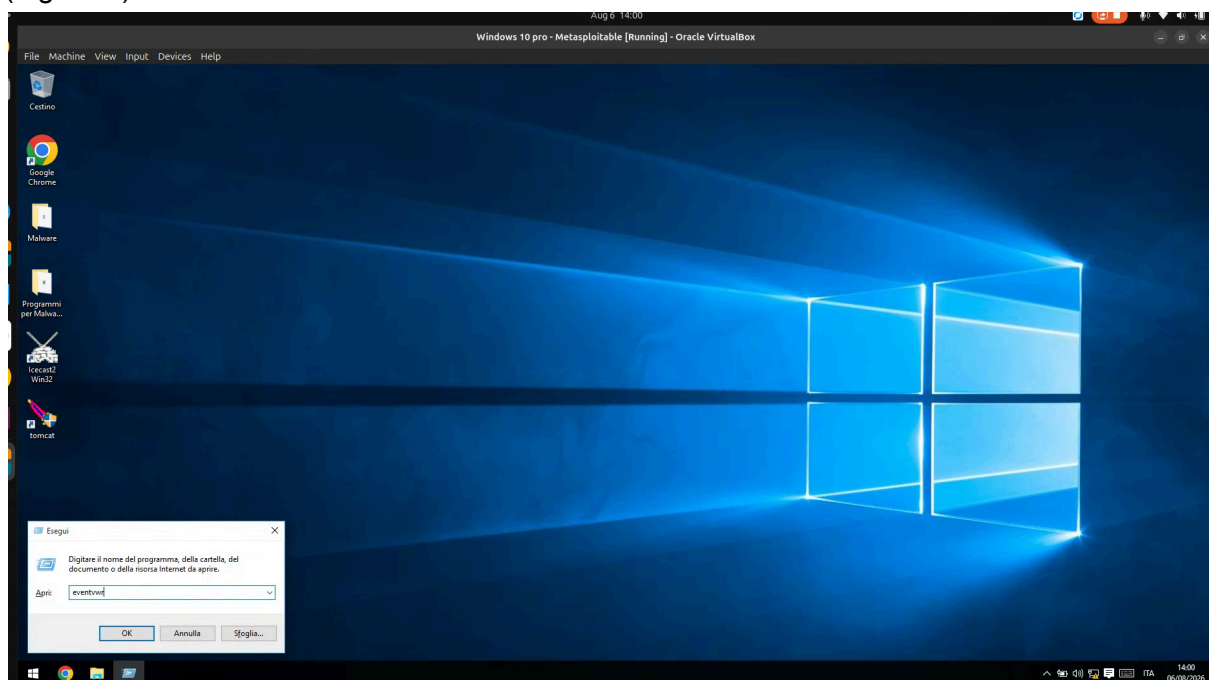
Fogli di calcolo

| Parametro            | Descrizione                                                                                                      |
|----------------------|------------------------------------------------------------------------------------------------------------------|
| Sistema Operativo    | Microsoft Windows 10 Pro                                                                                         |
| Ambiente             | Macchina virtuale isolata (laboratorio didattico)                                                                |
| Strumenti Utilizzati | Visualizzatore eventi ( <code>eventvwr.msc</code> ), Editor criteri di gruppo locali ( <code>gpedit.msc</code> ) |
| Utente               | Account con privilegi amministrativi locali                                                                      |

L'isolamento dell'ambiente garantisce che le modifiche apportate ai criteri di sicurezza e alle configurazioni di sistema non impattino su infrastrutture operative, preservando l'integrità dei sistemi di produzione e il rispetto delle policy di sicurezza aziendali e accademiche.

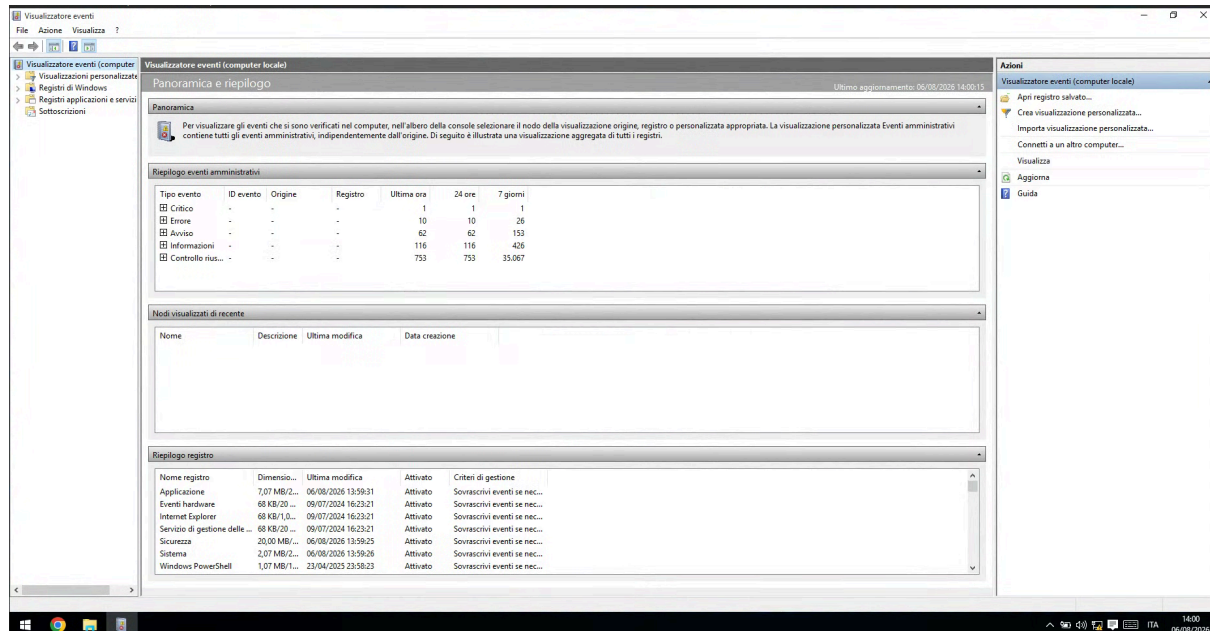
## 3. Fase 1: Analisi Preliminare del Registro di Sicurezza

La prima fase dell'esercitazione ha previsto l'accesso al Visualizzatore eventi, strumento nativo di Windows per la consultazione e la gestione dei registri di sistema. L'apertura dello strumento è stata effettuata mediante la combinazione di tasti **Win + R** per invocare la finestra di dialogo *Esegui*, digitando il comando `eventvwr` e confermando con il tasto *Invio* (Figura 1).



**Figura 1 – Finestra di dialogo *Esegui* con il comando `eventvwr` per l'apertura del Visualizzatore eventi.**

Una volta avviato il Visualizzatore eventi, si è proceduto alla navigazione nell'albero della console, espandendo il nodo *Registri di Windows* e selezionando la voce *Sicurezza*. Il pannello centrale ha mostrato un elenco pre-popolato di eventi di sicurezza preesistenti, prevalentemente riconducibili a operazioni di gestione degli account utente (Figura 2). In particolare, è stato osservato un significativo numero di eventi con ID 4798, relativi all'enumerazione dell'appartenenza a gruppi locali, che testimoniano l'attività del sistema operativo in background.

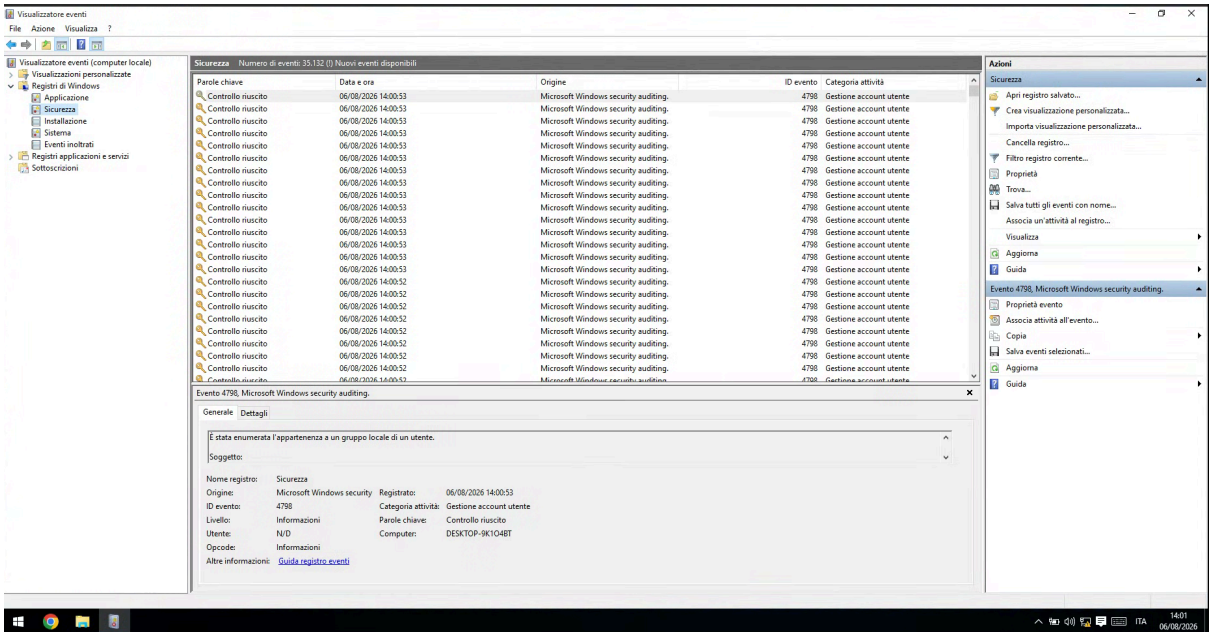


**Figura 2 – Interfaccia del Visualizzatore eventi con il registro *Sicurezza* selezionato. Sono visibili eventi pregressi (ID 4798) relativi alla gestione degli account utente.** Questa fase preliminare ha consentito di verificare lo stato iniziale del registro e di familiarizzare con la struttura delle informazioni registrate, inclusi i campi essenziali quali *Data e ora*, *Origine*, *ID evento*, *Categoria attività* e *Livello*.

## 4. Fase 2: Configurazione delle Proprietà del Log

Successivamente all'analisi preliminare, si è proceduto alla verifica e alla configurazione delle proprietà del registro di sicurezza. Mediante il clic con il tasto destro del mouse sulla voce *Sicurezza* e la selezione dell'opzione *Proprietà*, è stata aperta la finestra di dialogo

relativa (Figura 3).



**Figura 3 – Finestra *Proprietà registro - Sicurezza*. Sono evidenziati il percorso del file di log (%SystemRoot%\System32\winevt\Logs\Security.evtx), la dimensione corrente (20,00 MB) e la dimensione massima configurata (20.480 KB).**  
I parametri analizzati e confermati sono riportati nella Tabella 1.  
Fogli di calcolo

| Parametro                     | Valore / Impostazione                              | Note                                                                                  |
|-------------------------------|----------------------------------------------------|---------------------------------------------------------------------------------------|
| Nome completo                 | Security                                           | Nome nativo del registro di sistema                                                   |
| Percorso registro             | %SystemRoot%\System32\winevt\Logs\Security.evtx    | Percorso predefinito in formato .evtx (formato binario di Windows Vista e successivi) |
| Dimensione registro           | 20,00 MB (20.975.616 byte)                         | Spazio attualmente occupato sul disco                                                 |
| Dimensione massima            | 20.480 KB                                          | Limite massimo di archiviazione configurato                                           |
| Gestione in caso di log pieno | Sovrascrivi eventi se necessario (dal più vecchio) | Politica di rotazione automatica dei log                                              |

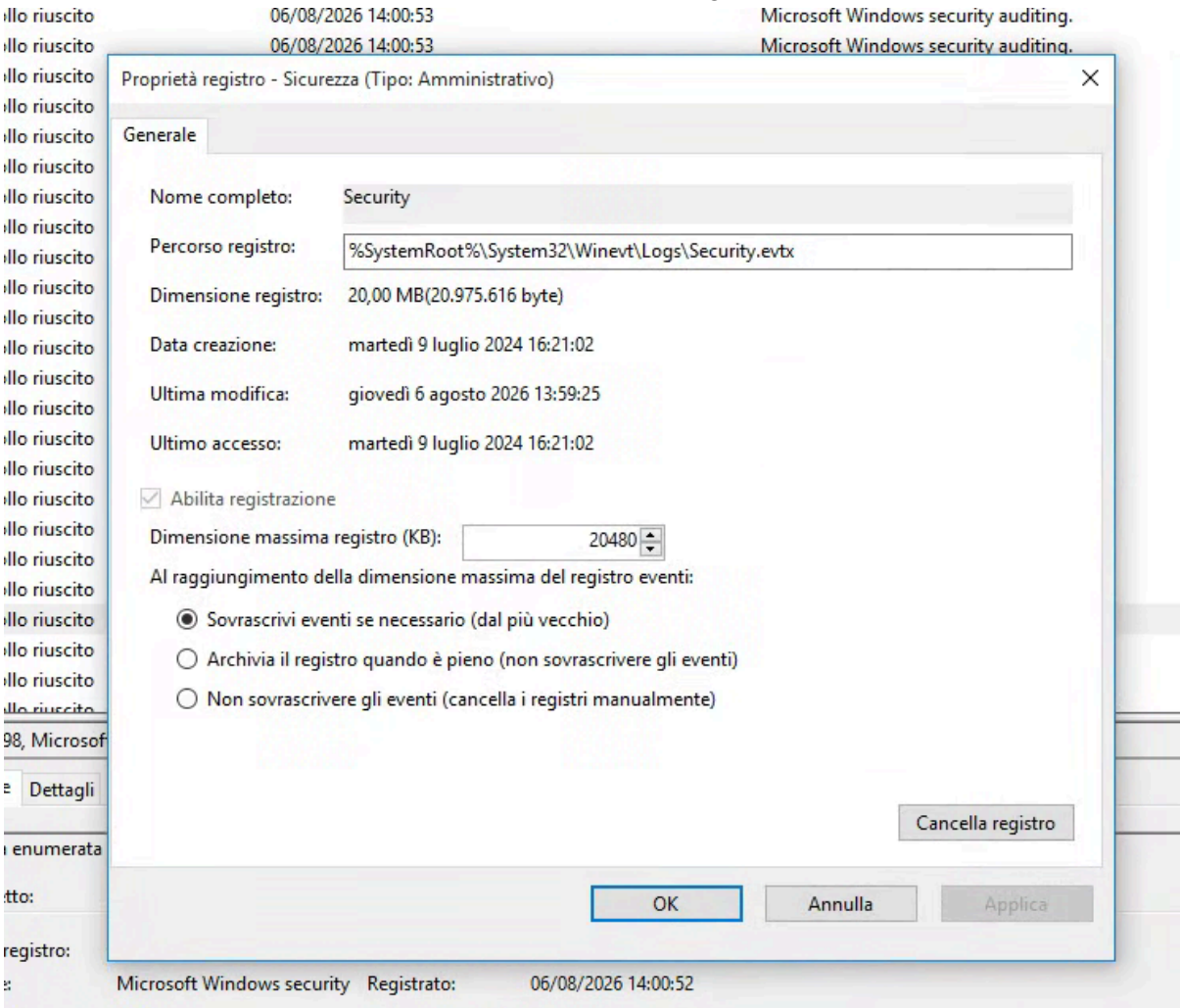
La configurazione della dimensione massima del registro rappresenta un aspetto critico della gestione della sicurezza. Un valore eccessivamente ridotto potrebbe comportare la sovrascrittura prematura di eventi rilevanti, compromettendo la capacità di condurre analisi forensi su attività passate. Viceversa, l'assenza di un limite dimensionale o una gestione inadeguata dello spazio disco potrebbero causare esaurimento delle risorse di archiviazione. La politica selezionata di sovrascrittura dei vecchi eventi, sebbene pratica per i sistemi con

risorse limitate, richiede un'attenta valutazione in ambienti di produzione, dove è generalmente preferibile l'archiviazione automatica o l'invio centralizzato dei log a un sistema *Security Information and Event Management* (SIEM).

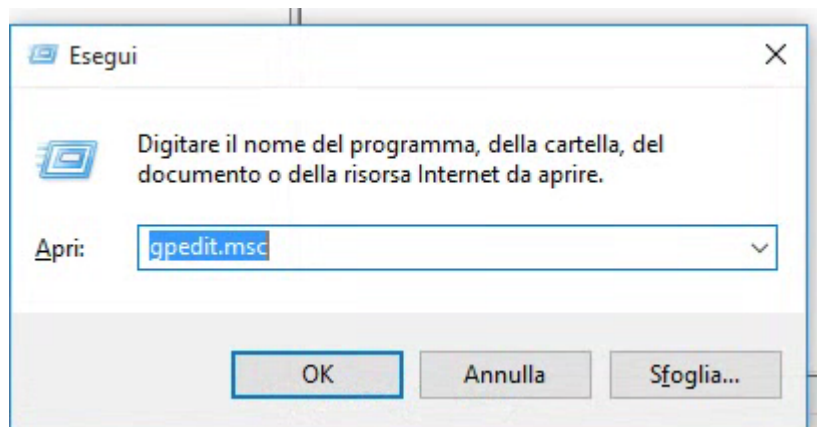
## 5. Fase 3: Configurazione delle Politiche di Audit per Accesso e Disconnessione

### 5.1 Accesso all'Editor Criteri di Gruppo Locali

Per abilitare la registrazione granulare degli eventi di accesso e disconnessione, si è fatto ricorso all'Editor criteri di gruppo locali (`gpedit.msc`), strumento che consente di definire le politiche di sicurezza a livello di computer locale. L'accesso è stato ottenuto, analogamente alla procedura precedente, tramite la finestra *Esegui* (Figura 4).



**Figura 4 – Finestra di dialogo *Esegui* con il comando `gpedit.msc` per l'avvio dell'Editor criteri di gruppo locali.**  
L'interfaccia dell'Editor (Figura 5) presenta una struttura ad albero che consente di navigare tra le configurazioni relative al computer locale e agli utenti.



**Figura 5 – Interfaccia iniziale dell'Editor criteri di gruppo locali (*Local Group Policy Editor*).**

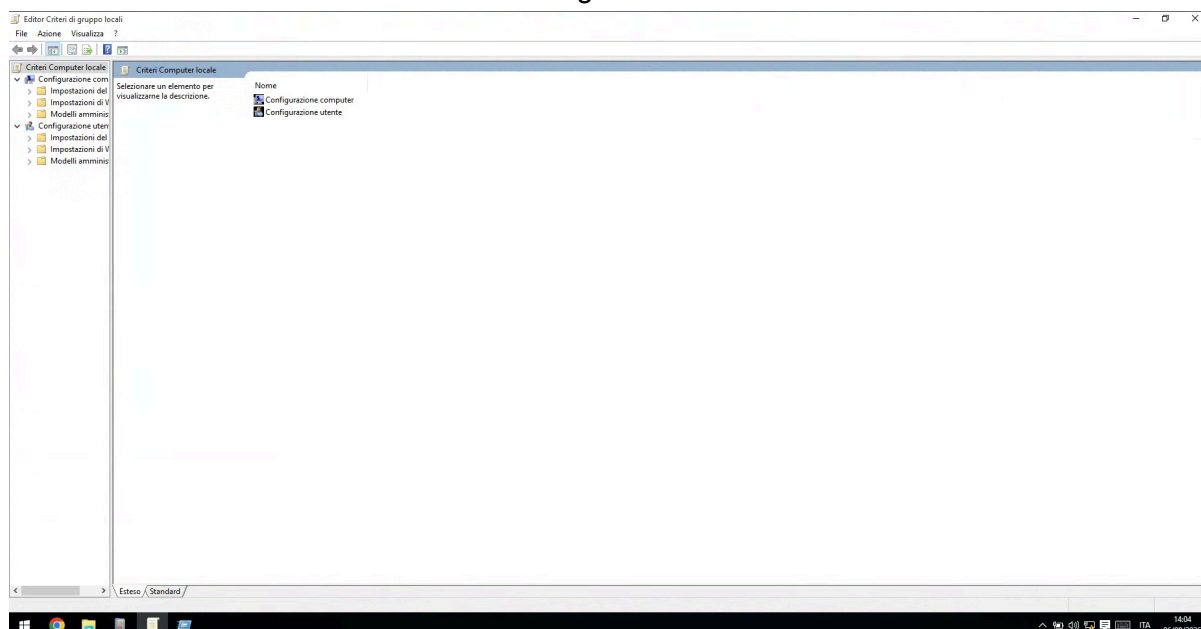
## 5.2 Configurazione dei Criteri di Controllo Avanzati

Al fine di garantire un controllo granulare e conforme alle best practice moderne di sicurezza, si è optato per l'utilizzo delle *Politiche di Controllo Avanzate (Advanced Audit Policies)*, che sostituiscono il tradizionale approccio dei criteri di controllo di base, offrendo una maggiore precisione nella selezione degli eventi da tracciare.

Il percorso di navigazione seguito è stato il seguente:

Configurazione computer > Impostazioni di Windows > Impostazioni di Sicurezza > Configurazione avanzata dei criteri di controllo > Criteri di controllo di sistema > Accesso/Disconnessione

All'apertura della sezione (Figura 6), è emerso che tutte le sottocategorie relative agli eventi di accesso e fine sessione erano inizialmente impostate su *Non configurata*, a conferma del fatto che il sistema non stava attivamente registrando tali eventi in modo differenziato.



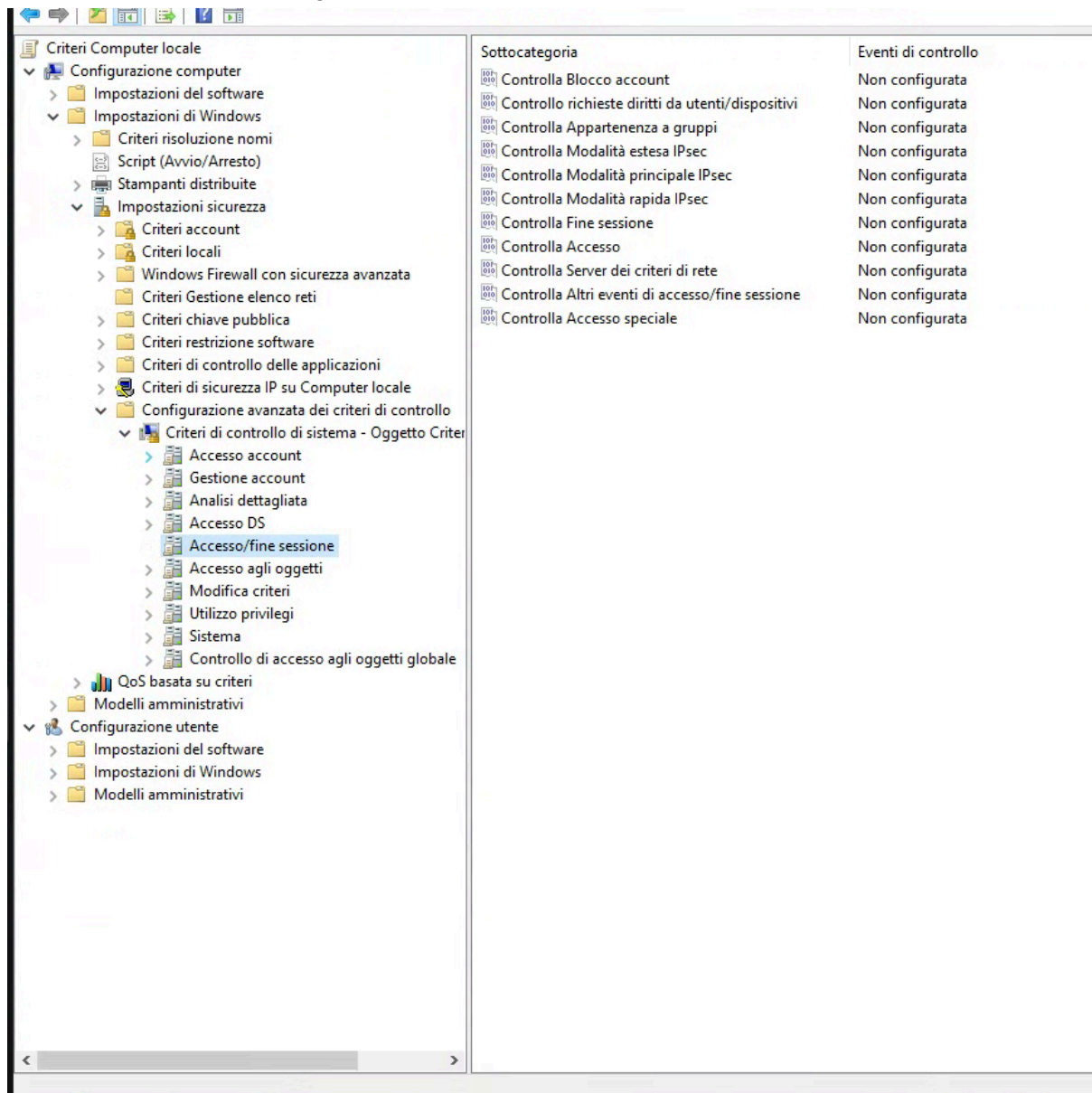
**Figura 6 – Sezione *Accesso/Disconnessione* dell'Editor criteri di gruppo. Lo stato iniziale di tutte le sottocategorie è *Non configurata*.**

Si è proceduto alla configurazione delle seguenti due sottocategorie fondamentali:

**a) Controlla Accesso (*Audit Logon*)**



Mediante doppio clic sulla voce *Controlla Accesso*, è stata aperta la relativa finestra delle proprietà. È stata abilitata l'opzione *Configura gli eventi di controllo seguenti* e selezionate le caselle *Operazione riuscita* e *Errore* (Figura 7). Tale configurazione consente di tracciare sia gli accessi effettuati con successo sia i tentativi di autenticazione falliti, fornendo visibilità completa sulle attività di login.



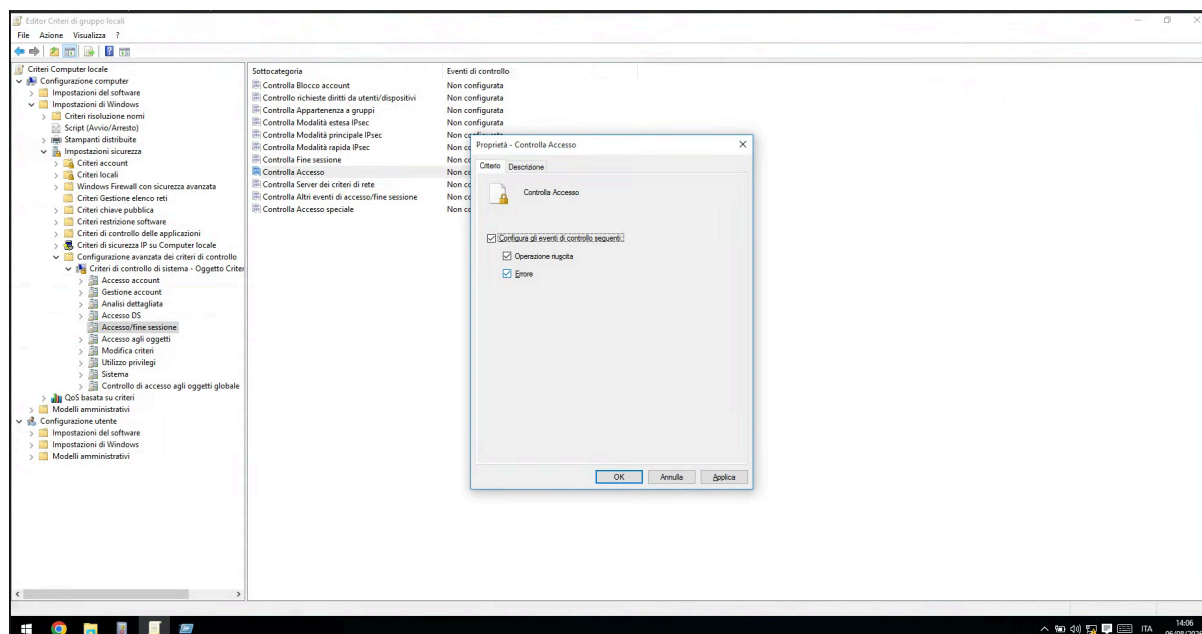
**Figura 7 – Finestra *Proprietà - Controlla Accesso*. Sono selezionate le opzioni *Operazione riuscita* e *Errore* per la registrazione completa degli eventi di accesso.**

**b) Controlla Fine sessione (*Audit Logoff*)**

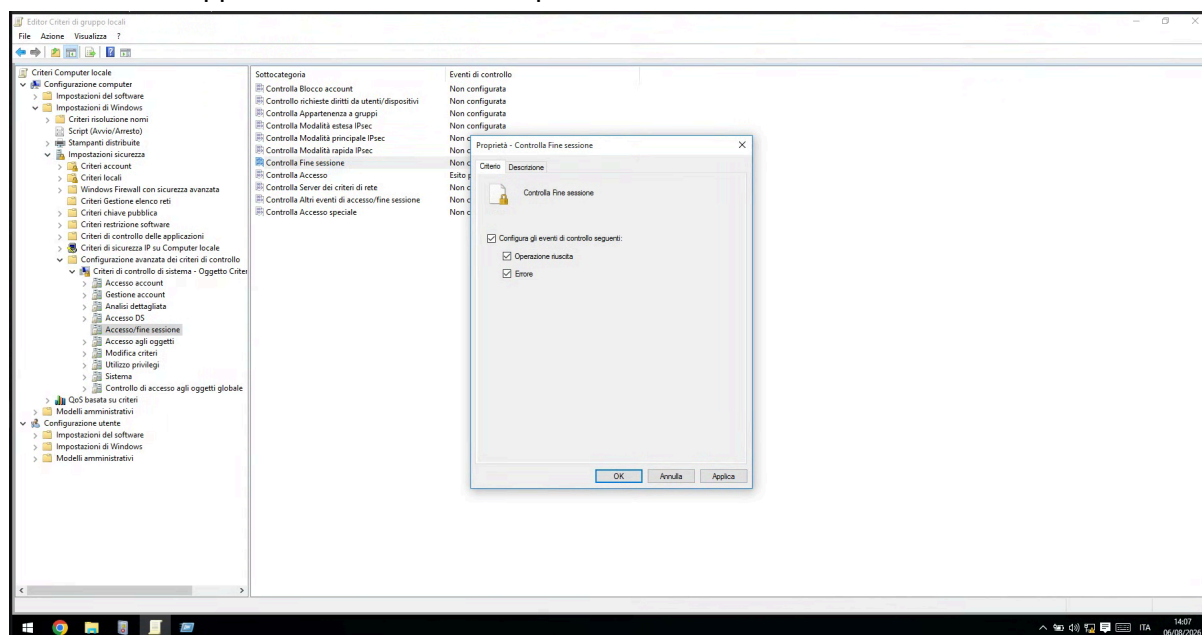
Analogamente, per la voce *Controlla Fine sessione*, sono state abilitate le opzioni *Operazione riuscita* e *Errore* (Figura 8), al fine di registrare le disconnessioni degli utenti dal



sistema.



**Figura 8 – Finestra *Proprietà - Controlla Fine sessione*. Sono selezionate le opzioni *Operazione riuscita* e *Errore* per la registrazione degli eventi di disconnessione.**  
Al termine delle configurazioni, la schermata riassuntiva ha mostrato lo stato aggiornato delle due sottocategorie, entrambe impostate su *Esito positivo* e *negativo* (Figura 9), a conferma dell'applicazione corretta delle politiche.

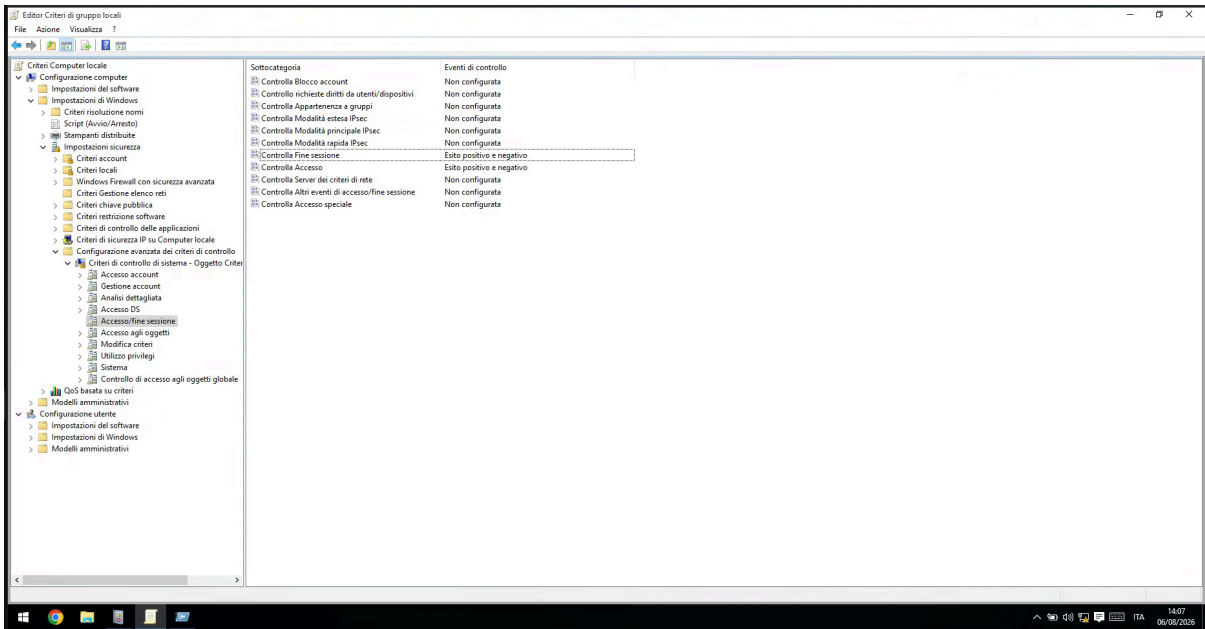


**Figura 9 – Stato finale delle sottocategorie *Controllo Fine sessione* e *Controllo Accesso*, entrambe configurate con *Esito positivo* e *negativo*.**

## 6. Fase 4: Verifica e Analisi degli Eventi Generati

Dopo l'applicazione delle politiche di audit, è stata condotta la fase di verifica per accertare l'effettiva generazione degli eventi di sicurezza attesi. A tal fine, si è proceduto a forzare la

generazione di eventi di accesso e disconnessione mediante il blocco e lo sblocco della sessione utente (utilizzando la combinazione **Win + L** seguita dalla riautenticazione). Successivamente, aggiornando il registro di sicurezza nel Visualizzatore eventi, è stato possibile osservare la comparsa di nuovi eventi coerenti con le politiche configurate (Figura 10).

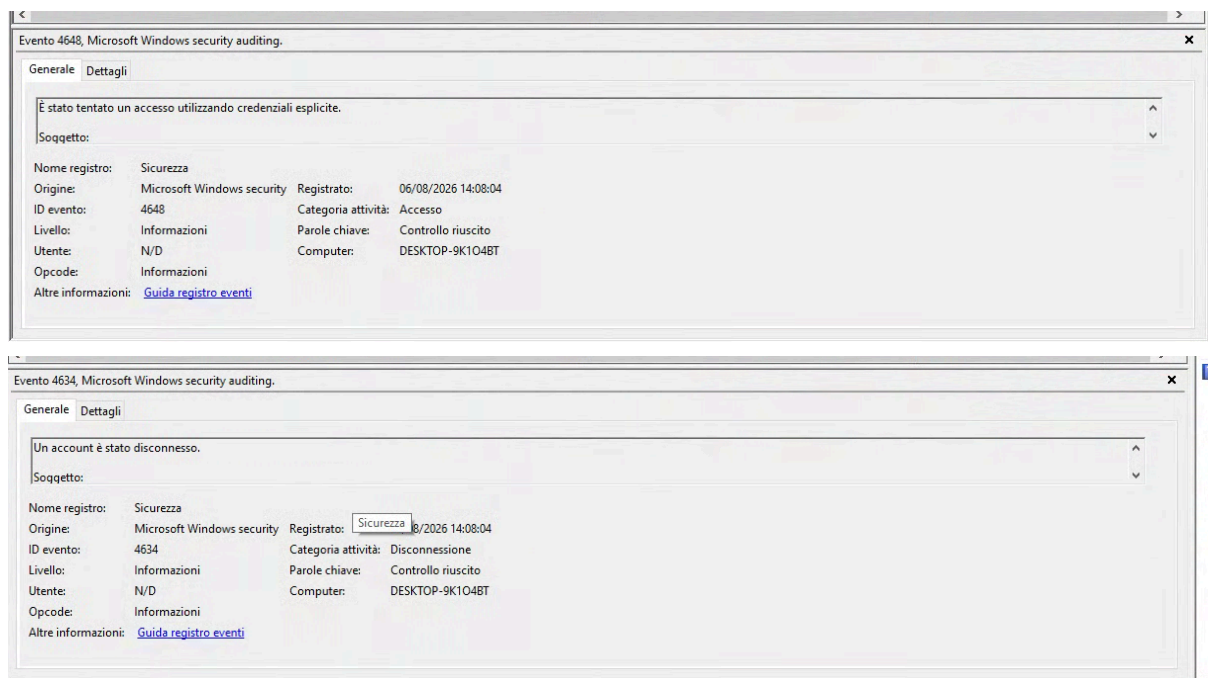


**Figura 10 – Estratto del registro di sicurezza aggiornato. Sono visibili gli eventi ID 4624 (Accesso), 4634 (Disconnessione) e 4648 (Accesso con credenziali esplicite).** L'analisi dettagliata dei singoli eventi ha permesso di identificare le seguenti tipologie:

- **Evento ID 4624 – Accesso riuscito:** indica che un utente ha effettuato con successo l'accesso al sistema. I dettagli dell'evento includono informazioni relative all'account, al tipo di accesso (interattivo, di rete, ecc.) e al workstation di provenienza.
- **Evento ID 4634 – Disconnessione account:** segnala la chiusura di una sessione utente. La Figura 11 mostra i dettagli di un evento 4634, con la descrizione testuale *"Un account è stato disconnesso"* e la correlata categoria di attività *Disconnessione*.
- **Evento ID 4648 – Accesso con credenziali esplicite:** documenta un tentativo di accesso nel quale le credenziali sono state fornite esplicitamente dall'utente o da un processo, anziché essere gestite automaticamente dal sistema (Figura 12).

| Parole chiave      | Data e ora          | Origine                              | ID evento | Categoria attività |
|--------------------|---------------------|--------------------------------------|-----------|--------------------|
| Controllo riuscito | 06/08/2026 14:08:04 | Microsoft Windows security auditing. | 4634      | Disconnessione     |
| Controllo riuscito | 06/08/2026 14:08:04 | Microsoft Windows security auditing. | 4634      | Disconnessione     |
| Controllo riuscito | 06/08/2026 14:08:04 | Microsoft Windows security auditing. | 4624      | Accesso            |
| Controllo riuscito | 06/08/2026 14:08:04 | Microsoft Windows security auditing. | 4624      | Accesso            |
| Controllo riuscito | 06/08/2026 14:08:04 | Microsoft Windows security auditing. | 4648      | Accesso            |

**Figura 11 – Dettaglio dell'evento ID 4634. La descrizione riporta *"Un account è stato disconnesso"*, con categoria di attività *Disconnessione* e livello *Informazioni*.**



**Figura 12 – Dettaglio dell'evento ID 4648. La descrizione riporta "È stato tentato un accesso utilizzando credenziali esplicite", utile per tracciare l'uso di credenziali in contesti specifici.**

La verifica ha confermato che le politiche di audit sono state applicate correttamente e che il sistema è ora in grado di generare tracce digitali dettagliate relative alle attività di autenticazione, fornendo un livello di visibilità essenziale per il monitoraggio della sicurezza.

## 7. Analisi dei Rischi e Contromisure

La gestione dei log di sicurezza costituisce una componente critica di ogni programma di cybersecurity. La mancata configurazione o una gestione inadeguata dei registri di audit espone le organizzazioni a una molteplicità di rischi, che possono compromettere sia la capacità di rilevare minacce in tempo reale sia la possibilità di condurre indagini forensi post-incidente.

### 7.1 Rischi Associati alla Mancata Configurazione degli Audit

1. **Cecità operativa (*Operational Blindness*):** in assenza di politiche di audit corrette, il sistema non genera evidenze relative agli accessi. Un attaccante che riesca a compromettere le credenziali di un utente potrebbe operare all'interno del sistema in modo completamente invisibile, senza lasciare tracce nel registro di sicurezza.
2. **Incapacità di rilevamento degli attacchi a forza bruta:** senza la registrazione degli eventi di accesso fallito (ID 4625), un tentativo di attacco a forza bruta contro gli account locali non lascerebbe tracce utilizzabili per l'attivazione di allarmi o il blocco automatico degli account.
3. **Mancata tracciabilità delle azioni degli insider:** in contesti aziendali, la capacità di ricostruire la cronologia degli accessi di un utente è fondamentale per indagare su eventuali comportamenti malevoli o non autorizzati da parte di soggetti interni (*insider threat*).

4. **Non conformità normativa:** framework e standard quali ISO/IEC 27001, il *NIST Cybersecurity Framework* e il regolamento GDPR impongono il mantenimento di registri di accesso per garantire la riservatezza, l'integrità e la disponibilità delle informazioni. La mancata conservazione dei log può comportare sanzioni significative.
5. **Perdita di evidenze forensi:** in caso di incidente di sicurezza, i log rappresentano la principale fonte di prove digitali. Una politica di sovrascrittura troppo aggressiva o una dimensione insufficiente del registro possono causare la perdita irreversibile di informazioni critiche.

## 7.2 Contromisure e Best Practices

Per mitigare i rischi sopra descritti, è necessario adottare un approccio olistico alla gestione dei log, che trascenda la semplice abilitazione degli audit:

Fogli di calcolo

| Categoria           | Contromisura                     | Descrizione                                                                                                                                                             |
|---------------------|----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Prevenzione</b>  | Principio del minimo privilegio  | Limitare gli accessi amministrativi per ridurre la superficie di attacco e la quantità di log generati da attività non essenziali.                                      |
| <b>Raccolta</b>     | Centralizzazione dei log (SIEM)  | Inoltrare i log di sicurezza a una piattaforma SIEM (es. Splunk, ELK Stack, Wazuh) per garantire persistenza, correlazione tra eventi e analisi in tempo reale.         |
| <b>Protezione</b>   | Integrità dei log                | Proteggere i file di log dalla modifica o cancellazione non autorizzata mediante liste di controllo degli accessi (ACL) rigorose e, ove possibile, firma crittografica. |
| <b>Gestione</b>     | Dimensionamento e archiviazione  | Aumentare la dimensione massima del registro o configurare l'archiviazione automatica quando il log è pieno, preservando le evidenze storiche.                          |
| <b>Monitoraggio</b> | Regole di correlazione           | Definire regole di rilevamento delle anomalie (es. multipli accessi falliti in sequenza rapida, accessi fuori orario lavorativo) per identificare potenziali minacce.   |
| <b>Risposta</b>     | Piano di risposta agli incidenti | Integrare l'analisi dei log nelle procedure di <i>incident response</i> , definendo ruoli, responsabilità e tempistiche per la conservazione delle evidenze.            |

Inoltre, in un'ottica di *Zero Trust Architecture*, ogni richiesta di accesso — indipendentemente dalla provenienza — deve essere considerata potenzialmente ostile fino a prova contraria. I log di sicurezza rappresentano il meccanismo attraverso il quale si attua il principio fondamentale della verifica continua (*continuous verification*).

---

## 8. Considerazioni Finali e Lezioni Apprese

L'esercitazione condotta ha permesso di acquisire una comprensione approfondita del ruolo centrale svolto dai registri di sicurezza nella difesa dei sistemi operativi Windows. La configurazione degli audit avanzati per gli eventi di accesso e disconnessione, sebbene tecnicamente semplice, riveste un'importanza strategica fondamentale: essa costituisce il primo passo verso l'istituzione di un sistema di monitoraggio efficace e di una capacità di risposta agli incidenti strutturata.

Le principali lezioni apprese possono essere così sintetizzate:

- **La visibilità è prerequisito della sicurezza:** senza log accurati e dettagliati, qualsiasi sistema di rilevamento delle intrusioni (IDS) o sistema di risposta agli incidenti (IR) opera in condizioni di grave svantaggio informativo.
- **La granularità conta:** l'adozione delle politiche di controllo avanzate, rispetto ai criteri di base, consente di evitare il rumore informativo (*noise*) generato da eventi irrilevanti, focalizzando l'attenzione sugli indicatori di compromissione (IoC) effettivamente significativi.
- **La gestione del ciclo di vita dei log è critica:** la mera abilitazione degli audit è insufficiente; è necessario progettare fin dall'inizio politiche di retention, archiviazione e protezione che garantiscano la disponibilità e l'integrità delle evidenze nel tempo.
- **Il contesto didattico come fondamento etico:** l'esercitazione in ambiente controllato ha evidenziato come le stesse competenze tecniche utilizzate per proteggere un sistema possano essere deviate per scopi malevoli. La formazione in ethical hacking impone pertanto una rigorosa disciplina deontologica, nella quale il rispetto dei confini legali e istituzionali è non negoziabile.

In conclusione, l'attività svolta conferma che la cybersecurity non può essere ridotta a una mera questione tecnologica, ma deve essere intesa come un processo continuo che integra persone, processi e tecnologie. La capacità di registrare, analizzare e interpretare gli eventi di sicurezza rappresenta una delle competenze fondamentali per chiunque operi nel campo della difesa informatica, costituendo il terreno su cui si edificano tutte le successive attività di analisi della minaccia e risposta agli incidenti.